

Project One

Francisco Sousa

SNHU

IT 253

Instructor Scott Maples

04/05/26

Information Security Risk Assessment: Recommendations and Action Plan

Introduction

A recent review conducted by an external security specialist uncovered multiple critical weaknesses within our information security framework that must be addressed without delay. Responding to these issues goes beyond a purely technical task; it is essential to the overall success of the business. As the company moves toward ambitious global growth, with plans to increase revenue by 20% and expand into international markets, maintaining customer trust and ensuring consistent system performance are vital. Our e-commerce operations and manufacturing supply chain must remain reliable and resilient. A major cyber incident, such as a ransomware attack, could disrupt business operations, harm our reputation, and weaken the confidence our customers place in us. Taking action on the recommendations outlined in this report will help minimize risk, reinforce our commitment to safeguarding customer information, and strengthen our position as a secure and dependable global retailer.

Laws and Regulations

As a publicly listed organization, we must comply with the requirements of the Sarbanes-Oxley Act of 2002 (SOX). Although this law is centered on financial reporting accuracy and accountability, it also places important demands on information systems and security practices that affect our daily operations. Under SOX, organizations are expected to enforce strict access controls for financial applications, follow structured procedures when making system changes, ensure that data backups are dependable and can be restored when needed, and use security measures that can identify and address potential breaches.

The consultant's report highlighted several areas of concern, such as the lack of a formal business continuity strategy, the use of unprotected backup data, shared administrative credentials, and outdated security policies. These issues indicate weaknesses that could affect our ability to meet SOX expectations.

In addition to SOX requirements, operating in a global marketplace introduces further regulatory responsibilities. Regulations like the General Data Protection Regulation (GDPR) require organizations to safeguard personal information through effective technical solutions and well-defined organizational practices. By resolving the issues identified in the assessment, we can strengthen compliance with these regulations while reducing exposure to legal and operational risks.

Technical Controls

Technical controls address the technology-based vulnerabilities identified in the consultant's report. The following recommendations align with industry-recognized security frameworks such as the National Institute of Standards and Technology (NIST) Cybersecurity Framework and the Center for Internet Security (CIS) Critical Security Controls.

-
- **Upgrade wireless encryption to WPA3.** The assessment revealed that the current wireless network relies on WEP, a legacy encryption method that can be easily compromised. Transitioning to WPA3 will provide a much stronger level of protection for wireless communications across all company sites (NIST, 2018).

- **Adopt centralized log management.** At present, system and security logs are dispersed rather than consolidated, which limits visibility during security investigations. Implementing a Security Information and Event Management (SIEM) solution will collect and correlate log data from across the environment, improving monitoring capabilities and accelerating incident response (CIS, 2021).
- **Enable automatic workstation locking.** The review observed multiple instances of unattended devices remaining logged in. Introducing screen locks that activate after brief inactivity will reduce the risk of unauthorized access to open user sessions (NIST, 2018).
- **Apply encryption to mobile devices and backups.** Portable devices and locally stored backup data are currently not protected by encryption. Enforcing full-disk encryption on laptops and mobile devices, along with securing backups through encryption and relocating them to off-site or cloud-based storage, will help safeguard sensitive information in cases of loss or theft (CIS, 2021).
- **Automate antivirus updates.** A significant portion of endpoints have outdated antivirus definitions exceeding 30 days. Implementing centralized management with automatic updates will ensure all systems remain consistently protected against current threats (CIS, 2021).

Administrative Controls

Administrative controls address the people and process vulnerabilities identified in the report and are emphasized in frameworks such as National Institute of Standards and Technology (NIST).

- **Revise the information security policy.** The existing policy has not been updated in several years and no longer aligns with the organization's current risk landscape. It should be reviewed and revised immediately, with a defined schedule for annual updates moving forward (NIST, 2018).
- **Establish a security awareness and phishing training program.** All employees should be required to complete ongoing training that covers how to identify phishing attempts, follow strong password practices, and properly report suspected incidents (CIS, 2021).
- **Remove shared administrator accounts.** Using common administrative credentials prevents proper accountability for system activity and introduces compliance concerns, particularly under SOX requirements (Sarbanes-Oxley Act, 2002).
- **Create a business continuity and disaster recovery plan.** A structured plan should be developed to define recovery priorities, timelines, and procedures so the organization can maintain operations and recover effectively from disruptions (NIST, 2018).

Physical Controls

Physical controls protect our facilities, equipment, and data center from unauthorized access and environmental threats, as recommended by National Institute of Standards and Technology (NIST).

- **Secure headquarters building access.** All entry points must be secured with badge access controls, and employees must be trained to prevent tailgating (NIST, 2018).

- Restrict data center access by role. Access must be limited to authorized personnel only, with proper logging of all access events (CIS, 2021).

- Install backup and generator power in the data center. Implementing uninterruptible power supplies and backup generators ensures system availability and protects against outages (NIST, 2018).

Business Impact

Implementing these measures will require an initial commitment of time, funding, and personnel. However, the consequences of inaction present a far more significant risk to the organization. A ransomware attack on our e-commerce platform could halt sales operations entirely, potentially costing the company millions in lost revenue and recovery costs, a direct threat to our goal of increasing revenue by 20%. A data breach exposing customer information could trigger regulatory penalties under SOX and GDPR, generate costly litigation, and permanently damage the brand we are trying to expand globally. The recommended controls will directly support our business objectives by keeping our e-commerce platform available and reliable, protecting the customer data that underpins our reputation, ensuring SOX compliance to avoid financial and criminal liability, and building the security foundation necessary to support our planned global expansion. These recommendations will also require updates to existing security policies and practices. The outdated information security policy will be replaced with a current, comprehensive document. Role-based access controls and individual accountability will replace the shared IT administrator account. Regular training will shift security from a departmental concern to an organization-wide responsibility (NIST, 2018).

Conclusion

The findings from our third-party security evaluation paint a clear picture: our current security posture carries risks that are incompatible with our growth ambitions and compliance obligations. The vulnerabilities identified from unsecured building access and outdated wireless encryption to unencrypted backups and a complete absence of a disaster recovery plan leave the company exposed on multiple fronts simultaneously. Addressing these issues is not optional. SOX compliance is a legal requirement, and customer data protection is a business obligation. More importantly, our ability to grow, expand into new markets, and earn the trust of a global customer base depends on demonstrating that we take security seriously. I am asking leadership to approve and fund the implementation of the technical, administrative, and physical controls outlined in this memo. Acting now, before an incident occurs, is significantly less costly than responding after one does. By acting on these recommendations, we will not only close the high-risk gaps identified by the consultant but also build a security foundation that supports our aggressive growth targets while protecting shareholder value.

References

Center for Internet Security. (2021). *CIS Critical Security Controls (Version 8)*.

European Union. (2016). *General Data Protection Regulation (GDPR)*.

National Institute of Standards and Technology. (2018). *Framework for Improving Critical Infrastructure Cybersecurity*.

Sarbanes-Oxley Act of 2002, Pub. L. No. 107-204, 116 Stat. 745.